Scoring "Secure by Default": A Reproducible, CRA-Grounded Metric with a Drone Command-Link Instantiation

Ian Brighouse
Brighouse Security Labs, Spain
research@brighousesec.com

***Abstract*—The EU Cyber Resilience Act makes "secure by default" a legal requirement, but a requirement one cannot measure is a requirement one cannot audit. We propose a small, transparent metric that turns the *observable* security posture of a connected product's protocol endpoint into a 0–100 score with a letter grade, and we instantiate it on the MAVLink command links of two drone flight stacks. The metric is defined by three axioms—*provenance* (every criterion is computed from an observed finding or a model property, never from opinion), *monotonicity* (improving posture never lowers the score), and *CRA-grounded weights* (each criterion maps to an Annex I essential requirement and carries a fixed weight summing to 100)—and is released as executable code with a property-test suite that checks the axioms. Applied to our measured configurations, the score separates insecure defaults (grade E) from a provisioned but console-exempt link (grade D) and from a cleanly signed link (grade C), and ranks them below an idealised target (grade A), with grade B the ceiling for MAVLink 2 signing alone; the console-exemption penalty is captured numerically rather than described, and a criterion for a *second*, non-MAVLink control plane reorders two configurations that the MAVLink criteria alone rank equally. We argue that such a metric is the missing piece between a measurement tool and a conformity-evidence artefact, and we discuss its limits as a rubric rather than a canonical truth.**

***Index Terms*—secure by default, security metrics, Cyber Resilience Act, conformity evidence, MAVLink, measurement.**

I. Introduction

Regulators now treat an insecure default as a product defect, and auditors will need to say, repeatably, whether a given product meets the bar and by how much. Existing regulatory crosswalks are process-level—mapping a regulation to a control catalogue or another standard [1]–[3]—and stop short of a number computed from the product's actual behaviour. We close that gap for a concrete, measurable endpoint: the command-and-control (C2) link of an unmanned aircraft. Building on a passive/active auditor and an acceptance model from companion work [4], [5], we define a score whose inputs are exactly the findings those tools already produce.

Contributions. (i) A metric defined by three axioms, with CRA-grounded weights (Section II). (ii) An executable implementation and a property-test suite that checks the axioms (Section III). (iii) A validation on measured drone C2 links showing the metric discriminates posture, including a numeric penalty for the console-exemption behaviour (Section IV).

II. The Metric

Let an *observation* be the output of auditing one protocol endpoint: for MAVLink, the fraction of signed frames, whether an unsigned read is answered, whether an unauthenticated service (file transfer) is exposed, whether legacy framing is present, the firmware identity, and—from the model—whether key provisioning opens a trust-on-first-use window. A *criterion* c has a weight w_c and a satisfaction fraction $m_c \in [0, 1]$ computed from the observation. The score is

$$\text{Score} = \sum_{c \in C} w_c \, m_c, \qquad \sum_{c \in C} w_c = 100.$$

Table I lists the criteria, their CRA Annex I, Part I(2) anchor, and their weight. Weights reflect the CRA's emphasis on command-channel integrity and access control; confidentiality and maintenance are lighter for a C2 link. The criteria set is *versioned*, and the version is reported with every score, because adding a criterion changes every number: scores from different versions are not comparable. The set below is v2, which splits v1's single "unauthenticated service exposure" criterion (16) into the file-transfer surface (8) and a *second control plane* (8). The split is not cosmetic. A flight controller may expose a control path that is not MAVLink at all—PX4's uXRCE-DDS bridge reaches uORB directly and its transport is unauthenticated by design—and a MAVLink signing key does not protect it. A deployment can therefore satisfy every MAVLink criterion and still be commandable by another route, which a metric that scores only one protocol would rate as clean.

a) Axioms: **A1 Provenance:** each m_c is a function of an observed finding or a model property; none is a free judgement. Two inputs are *declared* rather than observed by the audit itself and are therefore the places where an analyst's input enters: the provisioning criterion reads the model-policy name the analyst assigns to the stack, and the confidentiality criterion reads a flag stating whether the link is encrypted. Both are recorded in the breakdown, so a reviewer can see and contest them. A run that observed no frames and whose probe never completed is *unscorable* and receives no grade; absence of evidence is never scored as security. **A2 Monotonicity:** improving any observable (more signed frames, an unsigned read now rejected, a service now closed) does not decrease any m_c, hence not the score. **A3 Grounding:** each c cites an

TABLE I
CRITERIA, CRA ANCHOR, WEIGHT, AND THE OBSERVABLE THAT COMPUTES m_c.

criterion	CRA	w_c	observable (m_c)
integrity	I.2(f)	28	signed-frame fraction
access control	I.2(d)	24	unsigned read rejected
attack surface	I.2(j)	8	no unauth. file transfer
control plane	I.2(d)	8	no unauth. second plane
no legacy	I.2(b)	10	no MAVLink 1 on link
provisioning	I.2(d)	12	out-of-band keys (no TOFU)
confidentiality	I.2(e)	6	link payloads encrypted
maintenance	II.1	4	firmware identifiable

TABLE II
SECURE-BY-DEFAULT SCORE OF EACH MEASURED CONFIGURATION.

configuration	score	grade
IDEAL (model target)	100	A
ArduPilot 4.7.2 SERIAL1 signed	74	C
PX4 1.18 GCS signed	66	C
ArduPilot 4.7.2 ch0 signed	50	D
ArduPilot 4.7.2 ch0 default	22	E
PX4 1.17 GCS default	20	E
PX4 1.17 GCS provisioned	20	E
PX4 1.18 GCS default	14	E

Annex I requirement and $\sum w_c = 100$. These axioms make the number auditable: a reviewer can re-derive every point from the published finding set.

III. IMPLEMENTATION

The metric is a small module (`mavaudit.score`) that consumes a mavaudit report and an optional model-policy name (for the provisioning criterion, which a single audit cannot observe). A property-test suite encodes the axioms directly: weights sum to 100; the idealised observation scores 100; monotonicity holds under a sequence of single-observable improvements; every criterion in a breakdown cites a CRA clause; and partial credit is strictly increasing in the signed-frame fraction. The suite runs in continuous integration alongside the auditor's own tests.

IV. VALIDATION

We score each configuration measured in [4] (Table II, Fig. 1).

Four observations validate the metric against intuition and against the companion findings. First, insecure defaults cluster at the bottom (grade E, scores 14–20): zero signed frames and an answered unsigned read cost the two heaviest criteria at once. Second, the metric gives the console-exemption behaviour (companion result *R4*) a *numeric* penalty: the ArduPilot `ch0` link, which signs every outbound frame yet still answers unsigned requests, scores below the cleanly signed SERIAL1 link even though their signed-frame fractions are identical—because the access-control criterion reads the active probe, not the passive traffic. Third, the control-plane criterion

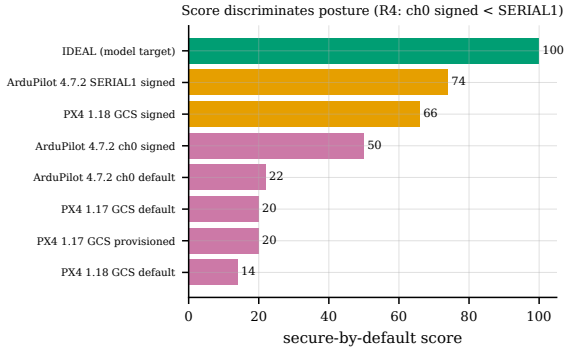


Fig. 1. Scores by configuration. Green ≥ 75, orange ≥ 55, red below. The console-exempt ArduPilot link (ch0, signed) scores strictly below the clean SERIAL1 link despite identical signed-frame fractions.

reorders two configurations that the MAVLink criteria alone rank equally: ArduPilot 4.7.2 signed on SERIAL1 (74) now sits above PX4 v1.18 signed (66), because the PX4 build offers an unauthenticated uXRCE-DDS plane and this ArduPilot build offers none. That ordering is invisible to a MAVLink-only metric, and it is the kind of reordering a metric has to be able to express if it is to be used as evidence. We note the asymmetry honestly: the absence is a property of *this* ArduPilot build, which does not compile the DDS subsystem, not of ArduPilot. A criterion that was never probed earns nothing and the score is reported as a lower bound, because a plane we did not look at is not a plane we know to be clean. Fourth, no measured configuration reaches grade A: every one either lacks confidentiality or keeps a trust-on-first-use window, so the idealised target (out-of-band keys, encrypted link) sits alone at the top. This deserves a plain statement, and a correction we owe an earlier draft. A link configured as well as MAVLink 2 signing alone allows—every frame signed, unsigned input rejected, no legacy frames, file transfer closed, no second plane, firmware identifiable—scores 82 (grade B), not more: the provisioning (12) and confidentiality (6) criteria are the remainder, and neither is in the protocol's gift. Confidentiality is simply absent from MAVLink 2, which authenticates frames without encrypting them, so it requires security underneath the protocol: an encrypted radio or a VPN. Provisioning is subtler—it is earnable, but only by distributing keys out of band in production, because the `SETUP_SIGNING`-over-the-link flow both stacks implement is precisely the trust-on-first-use window the criterion penalises. With out-of-band keys the ceiling rises to 94, and only with link encryption as well does 100 become reachable. The grade therefore combines a *protocol ceiling* with the integrator's configuration, and a reader should separate the two before judging a product: grade B is what signing alone can buy, and the step to grade A is a production practice and a radio, not a protocol fix. (An earlier draft of this paper put the ceiling "near 70, grade C". That was wrong: it quoted the best score we had measured, 74, as though it were the ceiling. The measured best falls short of 82 for mundane reasons—on that run the file-transfer status was unknown, drawing partial credit, and the firmware was

not identifiable on that link—and conflating a measurement with a bound is exactly the error a published metric should not make.) The score thus points at exactly the two upstream changes the companion synthesis identifies.

V. Discussion

The metric is a *rubric*, not a canonical truth: the weights encode a defensible reading of the CRA's emphasis, and a different regulator might choose differently. The axioms are what make it useful regardless: because the score is provenance-bound and monotone, two auditors applying the same weights to the same product get the same number, and improving the product can never be punished. The weights are a single, inspectable point of subjectivity, amenable to sensitivity analysis; the EU Trusted Drone label [6], once its criteria are published, could supply an authoritative weighting that this framework would then compute against. Threats to validity: the score covers one protocol endpoint, not a whole product; it assumes the auditor's findings are sound; and partial credit for the signed-frame fraction can over-reward a link that signs most but not all frames, which we mitigate by pairing it with the binary access-control criterion.

VI. Related Work

Security-metric research spans attack-surface and CVSS-style severity scoring; our contribution is narrower and complementary: a *default-posture* score grounded in a specific regulation and computed from live measurements. No prior "secure by default" scoring framework taking measured defaults as input was found in a search of the drone, IoT, and compliance literature [1], [7]. Companion work [4], [5], [8] supplies the measurements, model, and history the metric consumes.

VII. Conclusion

A measurement tool tells you what a product does; a regulation tells you what it must do; a metric with the right axioms connects them into a number an auditor can trust and a vendor can improve. Instantiated on drone C2 links, the score separates insecure defaults from partial and ideal postures, prices the console-exemption pitfall numerically, and points at the fixes. We release it as code so that the number is never a matter of opinion.

Availability

The metric, tests, and the data it scores are released at the project repository.[1] The work is defensive and simulation-based.

[1]Repository and data: https://github.com/brigghouse/brighouse-autonomy-lab

References

[1] J. Ruohonen, "SoK: The design paradigm of safe and secure defaults," *Journal of Information Security and Applications*, 2025, arXiv:2412.17329.

[2] G. Costantino, M. De Vincenzi, and I. Matteucci, "A comparative analysis of UNECE WP.29 R155 and ISO/SAE 21434," in *Proc. IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)*, 2022.

[3] F. Siddiqui, A. Ahlbrecht, R. Khan, S. Tasdemir, H. Hui, B. Sonigara, S. Sezer, K. McLaughlin, and W. Dürr, "Cybersecurity engineering: Bridging the security gaps in avionics architectures and DO-326A/ED-202A," in *Proc. IEEE/AIAA 42nd Digital Avionics Systems Conference (DASC)*, 2023, [VERIFY full author list].

[4] I. Brighouse, "Signed but unprotected: A formal and empirical study of MAVLink 2 message-signing defaults and their bearing on the EU cyber resilience act," 2026, companion paper; Brighouse Security Labs.

[5] ——, "Acceptance semantics for MAVLink 2 signing: Bounded symbolic analysis and model-based conformance testing of flight stacks," 2026, companion paper; Brighouse Security Labs.

[6] European Commission, "Action plan on drone and counter-drone security," COM(2026) 81 final, Brussels, 11 Feb. 2026, CELEX 52026DC0081, 2026.

[7] A. Puliyski, A. Stefanova, and V. Serbezov, "The regulatory illusion of security in drone operations in the specific category: An analysis of the gaps between regulatory compliance and actual cyber resilience within the SORA," *Transportation Research Procedia*, vol. 91, pp. 91–98, 2025.

[8] I. Brighouse, "A decade of defaults: How "secure by default" evolved in the MAVLink flight stacks," 2026, companion paper; Brighouse Security Labs.